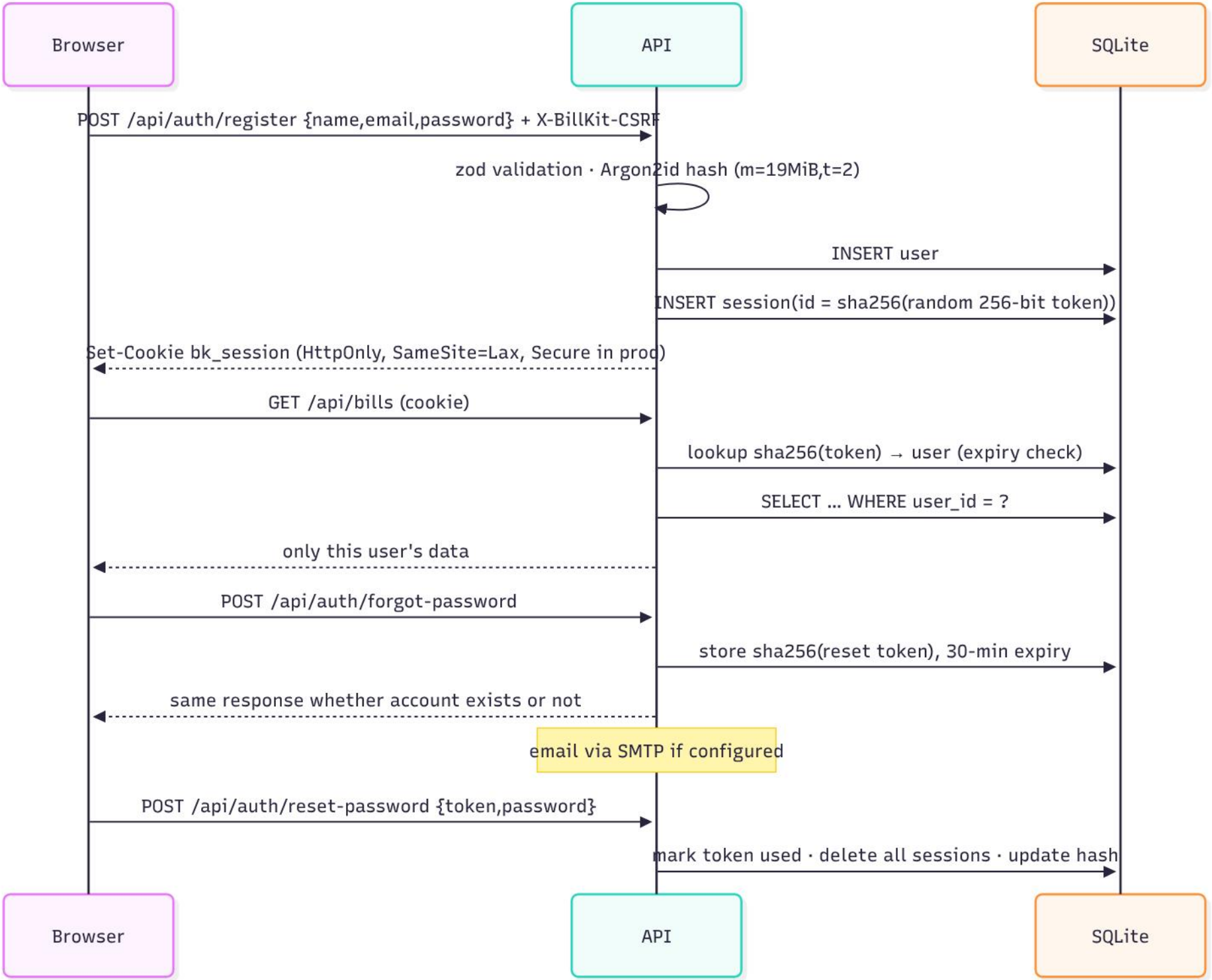

Browser
API
SQLite
POST /api/auth/register {name,email,password} + X-BillKit-CSRF
zod validation · Argon2id hash (m=19MiB,t=2)
INSERT user
INSERT session(id = sha256(random 256-bit token))
Set-Cookie bk_session (HttpOnly, SameSite=Lax, Secure in prod)
GET /api/bills (cookie)
lookup sha256(token) → user (expiry check)
SELECT … WHERE user_id = ?
only this user's data
POST /api/auth/forgot-password
store sha256(reset token), 30-min expiry
same response whether account exists or not
email via SMTP if configured
POST /api/auth/reset-password {token,password}
mark token used · delete all sessions · update hash
Browser
API
SQLite